Login and Account Management — Requirements Specification

This document describes the functional requirements for the login and account management module of a web application. It covers authentication, registration, password management, account security, and session handling.

1. Authentication

REQ-1.1: Email and password login

The system shall allow a registered user to log in using their email address and password.

REQ-1.2: Account lockout after failed login attempts

The system shall lock a user's account for 15 minutes after 5 consecutive failed login attempts within a 10-minute window. The user shall be shown a message indicating the account is temporarily locked and when they may try again.

REQ-1.3: Generic error message for invalid credentials

The system shall display a generic "invalid email or password" error message when login fails, without indicating whether the email address or the password was the incorrect field.

REQ-1.4: Fast and responsive login

The login experience should feel fast and responsive.

2. Account Registration

REQ-2.1: Required registration fields

The system shall require a user to provide a valid email address, a password, and their full name when creating a new account.

REQ-2.2: Email verification

The system shall send a verification email containing a confirmation link to the address provided at registration. The account shall remain unverified until the link is clicked.

REQ-2.3: Duplicate email prevention

The system shall prevent registration with an email address that is already associated with an existing account, and shall display a message directing the user to log in or reset their password instead.

3. Password Management

REQ-3.1: Password reset via email link

The system shall allow a user to request a password reset. A time-limited reset link shall be sent to the user's registered email address, and the link shall expire after 1 hour.

REQ-3.2: Password complexity requirements

The system shall require new passwords to be at least 10 characters long and contain at least one numeric digit and one symbol.

REQ-3.3: Timely delivery of reset emails

Password reset emails should be delivered quickly.

4. Account Security

REQ-4.1: Two-factor authentication

The system shall allow a user to enable two-factor authentication (2FA) using a time-based one-time password (TOTP) authenticator app.

REQ-4.2: Protection against common attacks

The system should be secure against common attacks.

5. Session Management

REQ-5.1: Automatic session timeout

The system shall automatically log out a user session after 30 minutes of inactivity, and shall require the user to log in again to continue.